

Introduction à la CyberSécurité

Sécurité des systèmes informatiques



Table des matières

Table des matières	2
Sécurité des systèmes informatiques.....	5
I. Fondamentaux de la sécurité informatique	5
A. Importance de la sécurité informatique	5
B. Portée des risques.....	6
C. Conséquences financières et risque de faillite.....	7
D. Menaces et risques liés aux nouvelles technologies.....	8
E. L'utilisateur et ses vulnérabilités.....	9
II. Obligations juridiques	10
A. Protéger les données.....	10
B. Organiser la preuve numérique	10
C. Sécuriser les échanges.....	10
III. Triangle CIA.....	11
IV. 5 Objectifs de la sécurité informatique.....	12
A. Intégrité des données.....	12
B. Authenticité des identifiants.....	12
C. Confidentialité des données	13
D. Non-répudiation des informations.....	13
E. Disponibilité des infrastructures et des données	13
V. SAIV, SIIV, OIV	14
A. SAIV – Secteurs d'activité d'importance vitale	14
B. OIV – Opérateurs d'importance vitale	15
C. SIIV – Système d'information d'importance vitale	15
VI. Organismes	16
A. ANSSI	16
B. CNIL.....	17
C. CERT & CSIRT	18
VII. Normes et cadres de Référence.....	21
A. Normes ISO.....	21
B. Cadres et réglementations européens.....	22
C. Cadres et réglementations internationaux	23

VIII. Métiers de la Cybersécurité.....	24
A. Métiers de la Sécurité Défensive	25
B. Métiers de la Sécurité Offensive	28
C. Métiers de la GRC.....	31
Menaces informatiques.....	33
I. Généralités.....	33
A. Infections informatiques	33
B. Motivations des attaquants	34
C. Types de programmes malveillants	35
D. Catégories de malwares	36
II. Reconnaissance passive	40
A. Informations cibles.....	40
B. Sources d'information	40
C. OSINT (Open Source Intelligence)	41
III. Reconnaissance Active	42
A. Ingénierie sociale (social engineering)	42
B. Écoute (sniffing)	43
C. Scan	44
IV. Types d'attaques principaux.....	45
A. Phishing	45
B. USB Dropping	46
C. Téléchargements malveillants	47
D. Spoofing.....	48
E. Man-In-The-Middle (MITM Attack).....	49
F. Session hijacking (vol de session).....	50
G. Attaque bruteforce ou par dictionnaire.....	51
H. Exploit.....	52
I. Attaques Web Client-Side	53
J. Attaques Server-Side	54
K. Déni de service (DoS – Denial of Service).....	56
V. Post exploitation	57
A. Etapes clés de la post-exploitation.....	57
B. Objectifs	58

Sécurité des systèmes informatiques

La sécurité informatique a pour mission d'assurer que les ressources matérielles, logicielles et les données d'une structure ou d'une personne soient utilisées dans le cadre prévu.

I. Fondamentaux de la sécurité informatique

A. Importance de la sécurité informatique

Généralités

Avec le développement et la généralisation des technologies numériques, la cybersécurité devient vitale pour les entreprises mais également pour les particuliers.

Les entreprises utilisent au quotidien des outils digitaux et des systèmes d'information. Ces dernières exploitent des données en interne mais également les données de leurs clients. Ces données constituent une ressource précieuse et critique. Une cyberattaque peut aboutir à une divulgation ou une altération des données de l'entreprise ou de ses clients, ce qui peut entraîner des conséquences désastreuses pour l'entreprise comme une faillite ou même des poursuites en justice.

L'objectif principal de la sécurité informatique est de protéger ces données. Ceci passe par plusieurs étapes :

- Evaluation des risques et de leur criticité
- Recherche, sélection et priorisation des réponses à ces risques
- Identification des vulnérabilités :
 - Audits
 - Tests d'intrusion et Red-Team
 - Bug Bounty
- Correction des vulnérabilités
- Mise en œuvre des protections choisies et vérification de leur efficacité

B. Portée des risques

Parmi les risques induits par une attaque informatique on peut citer :

Destruction

Données, infrastructures,
applications ou code

Indisponibilité

Partielle ou totale des systèmes
et/ou du réseau, potentiellement
prolongée

Utilisation illégale ou frauduleuse

Données, infrastructures,
ressources ou applications

Perte de secrets ou d'informations confidentielles

Perte d'investissement

Et par conséquent de son coût de
mise en place

Coût de remise en état du service

Rétablissement, reconstruction,
reconfiguration,
redéveloppement

Perte de productivité et/ou de revenus

Indisponibilité totale/partielle,
courte/prolongée de l'organisme
et/ou de ses partenaires

Atteinte à la réputation

Perte de crédibilité

Responsabilité légale

Divulgence et/ou exploitation
frauduleuse des données,
utilisation de services

Conséquences psychologiques

Faillite

C. Conséquences financières et risque de faillite



Les cyberattaques représentent un risque majeur pour les entreprises, en particulier pour les PME qui, faute de ressources et de préparation adéquates, peinent souvent à se remettre d'une attaque.

Un nombre significatif de PME se voient contraintes de fermer leurs portes après un incident, illustrant ainsi la vulnérabilité de ces structures et l'urgence d'investir dans des mesures de cybersécurité robustes.

Parallèlement, les statistiques de data.gouv.fr montrent que toutes les entreprises, quelle que soit leur taille, subissent des impacts économiques et opérationnels considérables, notamment en termes de coûts directs et de pertes de revenus.

Ces informations soulignent la nécessité de développer une stratégie proactive et une préparation renforcée pour atténuer les conséquences potentiellement fatales des cyberattaques et assurer la pérennité de l'entreprise.



« Le coût moyen d'une cyberattaque pour les entreprises reste élevé, bien que légèrement en baisse par rapport à l'année précédente, passant de 15 640€ à environ 14 720€. Cependant, une entreprise sur huit rapporte des coûts dépassant les 230 000€, soulignant ainsi la gravité des cyberattaques les plus destructrices. »

data.gouv.fr

« Entre 50 et 60 % des PME ayant été victimes de cyberattaques mettent la clé sous la porte dans les dix-huit mois qui suivent » Gérard VALLET – Directeur Régional Orange Cyberdefense

lemagit.fr

D. Menaces et risques liés aux nouvelles technologies

L'évolution rapide des nouvelles technologies engendre une multiplication des vecteurs d'attaques et des vulnérabilités. L'intégration de systèmes intelligents et interconnectés expose les organisations à des risques complexes, où des failles non anticipées peuvent être exploitées par des cybercriminels. Ces menaces imposent une veille technologique constante et une adaptation des stratégies de sécurité pour anticiper des attaques innovantes et souvent sophistiquées

Appareils mobiles et nomades

Les appareils mobiles et nomades représentent une surface d'attaque considérable du fait de leur usage quotidien en dehors des réseaux sécurisés.

La mobilité accrue et la connexion fréquente à des réseaux publics ou non sécurisés augmentent les risques de perte de données, de compromission des informations sensibles et d'intrusions malveillantes.

Ces enjeux nécessitent la mise en place de politiques de sécurité robustes et de solutions de gestion des terminaux pour assurer une protection adéquate.



Objets connectés



L'essor des objets connectés dans les environnements professionnels et domestiques a conduit à une prolifération de dispositifs souvent vulnérables par défaut. Ces équipements, intégrés dans l'Internet des Objets (IoT), peuvent servir de points d'entrée pour des attaques, permettant aux cybercriminels d'accéder à des réseaux étendus.

L'absence de protocoles de sécurité standardisés et la difficulté de déployer des mises à jour régulières accentuent le risque d'exploitation malveillante.

Omniprésence des données et risques du tout connecté

La numérisation massive et l'omniprésence des données favorisent une interconnexion permanente entre systèmes et utilisateurs. Cette réalité, tout en facilitant les échanges et l'accès à l'information, expose également les organisations à des risques liés à la surveillance, au vol ou à la manipulation des données.

L'intégration de multiples dispositifs et applications crée un écosystème complexe, où une faille dans un maillon peut compromettre la sécurité de l'ensemble du système.



BYOD

La politique Bring Your Own Device (BYOD) permet aux utilisateurs d'utiliser leurs appareils personnels afin d'accéder à des ressources professionnelles. Ceci offre une flexibilité appréciable aux collaborateurs, mais elle introduit également des défis majeurs en termes de sécurité.

L'utilisation de dispositifs personnels en environnement professionnel expose les réseaux aux risques de contamination et de fuite de données.



Bien qu'appréciée par les utilisateurs, cette politique constitue une approche risquée du point de vue de l'entreprise pour de nombreuses raisons :

- Manque de contrôle sur la sécurité des appareils personnels
- Risque accru de perte ou de vol d'appareils contenant des données sensibles
- Difficulté à appliquer des mises à jour et correctifs de sécurité en temps réel
- Possibilité d'infection par des malwares via des applications non vérifiées
- Séparation floue entre vie professionnelle et vie personnelle augmentant le risque de fuites de données

La mise en œuvre de stratégies de contrôle d'accès et de segmentation des réseaux, ainsi que la sensibilisation des utilisateurs, est essentielle pour concilier mobilité et protection des informations sensibles.

E. L'utilisateur et ses vulnérabilités



L'utilisateur constitue souvent le maillon faible et une cible de choix en matière de sécurité, car ses comportements et ses erreurs peuvent compromettre l'ensemble du système.

Les mauvaises pratiques, telles que l'utilisation de mots de passe simples ou le clic sur des liens suspects, exposent les organisations à des attaques ciblées. Il est crucial de renforcer la sensibilisation et la formation des utilisateurs pour atténuer ces vulnérabilités et instaurer une culture de la sécurité.

L'utilisateur représente le vecteur d'accès initial le plus vulnérable, car une faille dans ses pratiques peut rapidement être exploitée pour compromettre l'ensemble du réseau.

II. Obligations juridiques

A. Protéger les données



La protection des données à caractère personnel est une obligation légale majeure pour toutes les organisations. Mettre en place des mécanismes rigoureux de contrôle d'accès permet de garantir que seules les personnes autorisées puissent consulter et manipuler ces informations sensibles.

La conformité aux réglementations telles que le RGPD renforce la confiance des utilisateurs et prévient les sanctions juridiques

B. Organiser la preuve numérique

Organiser la preuve numérique consiste à structurer et sécuriser les données afin de garantir leur intégrité et leur valeur probante lors d'éventuels litiges. Cela implique l'utilisation de systèmes de traçabilité, d'archivage sécurisé et de procédures standardisées pour collecter et conserver les preuves digitales.

Une bonne organisation de la preuve numérique est essentielle pour assurer la transparence et la fiabilité des informations en cas de contentieux.



C. Sécuriser les échanges



La sécurisation des échanges vise à protéger les communications électroniques contre toute interception ou altération malveillante. L'adoption de protocoles de chiffrement, l'utilisation de certificats numériques et la mise en œuvre de systèmes d'authentification renforcée permettent de préserver l'intégrité et la confidentialité des données transmises.

Ces mesures de sécurité sont indispensables pour instaurer un climat de confiance et assurer la fiabilité des transactions, tant dans le domaine professionnel que personnel.

III. Triangle CIA

Le triangle CIA est un modèle fondamental qui repose sur trois piliers essentiels pour assurer la protection des données et des systèmes informatiques. Ces trois dimensions doivent être équilibrées pour garantir un niveau de sécurité optimal et résilient face aux menaces.

Les attaques informatiques cherchent à compromettre une ou plusieurs composantes du triangle CIA. La défense, quant à elle, met en place des mesures techniques et organisationnelles pour protéger ces trois aspects et assurer la sécurité globale des systèmes d'information



Confidentialité

Concerne le fait de veiller à ce que l'accès aux informations soit réservé uniquement aux personnes autorisées. Une attaque peut chercher à obtenir des données sensibles sans permission, compromettant ainsi la confidentialité des informations

Intégrité

Consiste à s'assurer que les données restent exactes et ne soient pas altérées. Une attaque peut viser à accéder à modifier ou altérer les données, affectant leur exactitude et leur fiabilité.

Disponibilité

Veiller à ce que les informations soient accessibles en temps voulu aux utilisateurs légitimes. Une attaque peut viser à accéder à rendre les systèmes ou services inaccessibles, perturbant ainsi leur fonctionnement normal.

IV. 5 Objectifs de la sécurité informatique

On dit communément que la cybersécurité comporte 5 objectifs majeurs. Ces derniers visent à garantir l'intégrité des données, l'authenticité des identifiants, la confidentialité des données, la non-répudiation des informations et la disponibilité des infrastructures et des données.

A. Intégrité des données

Cet objectif vise à assurer que les données restent fiables et qu'elles ne soient pas altérées ou modifiées durant tout leur cycle de vie. Ceci permet de préserver la validité et l'exactitude des données.



Il y a deux types d'intégrité qu'il est possible de distinguer, comportant chacun leurs processus et méthodes :

- Intégrité logique : désigne le fait de conserver les données au sein d'une base de données, dans leur état normal, sans changement au cours de leurs multiples manipulations
- Intégrité physique : désigne le fait de protéger les données lors de leur stockage, leur récupération et leur transport

B. Authenticité des identifiants



L'authentification est un mécanisme permettant de prouver l'identité d'un utilisateur.

Il existe de nombreux moyens d'arriver à cet objectif (mot de passe, biométrie, codes à usage unique, carte à puce, authentification double facteur...).

Le contrôle des accès est le mécanisme utilisé pour limiter l'accès ou l'utilisation de certaines ressources aux seules personnes qui disposent du droit et du besoin d'en connaître.

Le terme « authentification » est à ne pas confondre avec le terme « identification », la seconde désigne l'identifiant public (login généralement) tandis que le premier désigne le ou les élément(s) secret(s) connus de l'utilisateur.

Le mécanisme de contrôle des accès fait correspondre l'identifiant (public) et l'élément d'authentification (privé) afin de garantir l'authenticité de l'identifiant.

C. Confidentialité des données

Cet objectif vise à protéger les données d'accès illégitimes, de maintenir leur non-divulgaration et leur non-accessibilité par des personnes ou systèmes informatiques non autorisés.

En effet, toute personne ou entreprise dispose d'informations importantes voire critiques qu'il est impératif de garder secrètes. Ces informations peuvent par exemple concerner :

- Identifiants bancaires
- Données personnelles
- Informations stratégiques
- Informations contractuelles
- Brevets et processus de fabrication



D. Non-répudiation des informations



La non-répudiation des informations a pour but d'assurer que l'émetteur d'une information ne puisse nier être à l'origine de celle-ci.

Le moyen pour arriver à cet objectif est généralement la signature (traditionnelle ou numérique) des documents, des certificats et des emails. Ainsi, seul l'utilisateur possédant une clé privée peut apposer sa signature sur un email. Cette personne ne peut donc pas nier en être l'émetteur.

E. Disponibilité des infrastructures et des données

Les données doivent impérativement être disponibles et accessibles en permanence pour les personnes disposant d'un droit d'accès à celles-ci.

Cette notion est intimement liée avec l'attribution de droits d'accès précis et pertinents (lecture seule, lecture-écriture...)



V. SAIV, SIIV, OIV

A.SAIV – Secteurs d’activité d’importance vitale

En 2006, la France a mis en place le dispositif des Secteurs d'activité d'importance vitale (SAIV) pour protéger les opérateurs essentiels à la survie de la nation contre les actes malveillants et les risques majeurs

On compte 12 Secteurs d’Activité d’Importance Vitale (SAIV), répartis en 4 groupes principaux, chaque SAIV regroupant des opérateurs (OIV) dont l’activité est indispensable pour assurer les fonctions vitales du pays.

Chaque secteur est placé sous la responsabilité d'un ministère de tutelle chargé d'identifier, de désigner, et de contrôler les opérateurs concernés.

Liste des SAIV

Ces secteurs couvrent notamment les domaines de l'énergie, des transports, de la santé, des télécommunications, des finances, ou encore de l'industrie :

- Alimentation
- Gestion de l'eau
- Santé

Activités
humaines



- Activités civiles de l'Etat
- Activités militaires de l'Etat
- Activités judiciaires

Activités
régaliennes



- Énergie
- Finances
- Transports

Activités
économiques



- Communications électroniques, audiovisuel et information
- Industrie
- Espace et recherche

Activités
technologiques



B.OIV – Opérateurs d’importance vitale

Un OIV est une entité publique ou privée identifiée comme essentielle au bon fonctionnement ou à la survie de la nation.

Ces opérateurs sont désignés officiellement par arrêté ministériel par leur ministère de tutelle et soumis à des obligations spécifiques de sécurité pour protéger leurs systèmes d'information critiques (SIIV) contre les risques majeurs, notamment les cyberattaques, les sabotages ou le terrorisme.

Il existe plus de 200 opérateurs (publics ou privés) désignés OIV, dont la liste est classée secret défense. L'ANSSI (Agence Nationale de la Sécurité des Systèmes d'Information) accompagne ces OIV dans leur sécurisation et contrôle le respect des exigences réglementaires.

Principales obligations pour les OIV

- Identifier et déclarer leurs SIIV auprès de l'ANSSI selon les modalités définies par arrêté sectoriel
- Notifier immédiatement l'ANSSI des incidents affectant ces SIIV
- Appliquer les 20 règles techniques et organisationnelles définies par l'ANSSI, couvrant :
 - Gouvernance et pilotage
 - Maîtrise des risques
 - Maîtrise des systèmes d'information
 - Gestion des incidents
 - Protection des systèmes d'information
- Se soumettre aux contrôles de sécurité réalisés par l'ANSSI, par d'autres services de l'État, ou par des prestataires qualifiés (PASSI LPM)
- En cas de crise majeure, appliquer les mesures exceptionnelles décidées par le Premier ministre

C.SIIV – Système d’information d’importance vitale

Depuis fin 2013, la loi de programmation militaire impose aux OIV des exigences renforcées en matière de sécurité informatique pour protéger leurs systèmes d'information critiques, appelés Systèmes d'Information d'Importance Vitale (SIIV).

Les SIIV correspondent aux systèmes dont la compromission aurait des conséquences graves pour la nation (sécurité, économie, santé publique).

On peut noter que :

- Les SIIV doivent être formellement déclarés par l'OIV auprès de l'ANSSI
- Les incidents touchant les SIIV doivent être notifiés sans délai à l'ANSSI selon des critères définis par arrêté ministériel
- Les SIIV doivent respecter un référentiel strict de 20 règles de sécurité techniques et organisationnelles précisées par secteur
- L'ANSSI effectue des contrôles réguliers pour vérifier l'application des mesures de sécurité sur ces systèmes

VI. Organismes

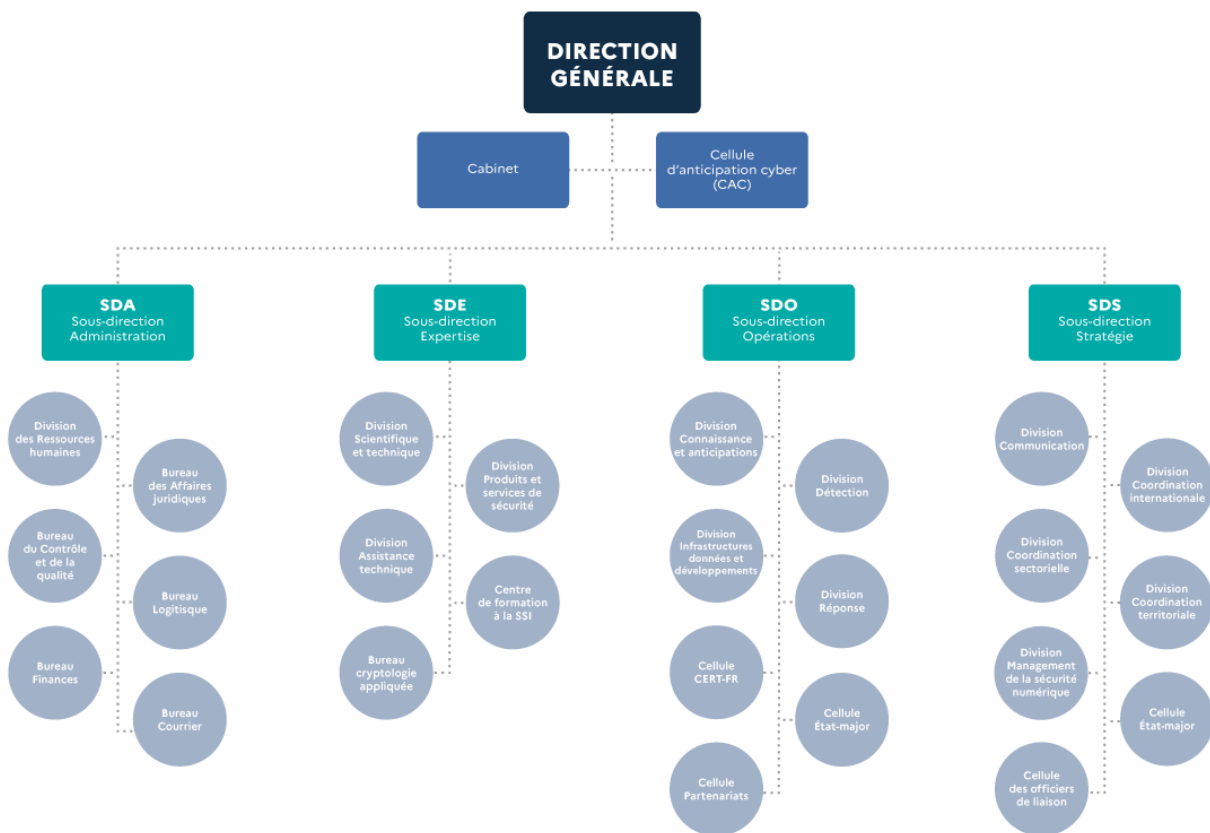
A.ANSSI

L'ANSSI (Agence nationale de la sécurité des systèmes d'information) est l'autorité nationale en matière de sécurité et de défense des systèmes d'information. Elle assure un service de veille, de détection, d'alerte et de réaction aux attaques informatiques.

L'ANSSI apporte son expertise et son assistance technique aux administrations et aux entreprises avec une mission renforcée au profit des opérateurs d'importance vitale (OIV) qui exploitent les installations indispensables à la vie du pays.

Au sein du centre de cyberdéfense de l'ANSSI, 24 sur 24, 7 jours sur 7, des hommes et des femmes se relaient pour protéger les citoyens et les intérêts vitaux de la Nation contre les attaques cyber. L'objectif est d'alerter sans délai les victimes potentielles, les autorités gouvernementales, voire les équipes techniques d'intervention en cas d'apparition de signes d'attaque informatique potentielle contre les intérêts de la Nation.

Concernant son organisation, l'ANSSI est rattachée au secrétaire général de la défense et de la sécurité nationale. Ce dernier assiste le Premier ministre dans l'exercice de ses responsabilités en matière de défense et de sécurité nationale.



B. CNIL

La Commission Nationale de l'Informatique et des Libertés (CNIL) a été créée par la loi Informatique et Libertés du 6 janvier 1978. Elle est chargée de veiller à la protection des données personnelles contenues dans les fichiers et traitements informatiques ou papiers, aussi bien publics que privés.



Son objectif principal est de veiller à ce que l'informatique soit au service du citoyen et ne porte atteinte ni à l'identité humaine, ni aux droits de l'homme, ni à la vie privée, ni aux libertés individuelles ou publiques.

Composée de 18 membres élus ou nommés, elle est une autorité administrative indépendante (AAI), un organisme public d'Etat qui n'est pas placé sous autorité gouvernementale ou ministérielle.

Elle joue un rôle d'alerte, de conseil et d'information vers tous les publics mais dispose également d'un pouvoir de contrôle et de sanction.

Ses missions sont les suivantes :

- Informer et protéger les droits (en faveur des particuliers et des professionnels)
- Accompagner vers la conformité et conseiller
- Anticiper et innover
- Contrôler et sanctionner

C. CERT & CSIRT

Les CERTs (Computer Emergency Response Team) sont des équipes spécialisées dans la réponse aux incidents informatiques et cyberattaques, ayant pour rôle de :

- Réagir rapidement et efficacement face aux incidents informatiques
- Coordonner les réponses techniques entre différentes entités
- Diffuser des alertes et des bonnes pratiques auprès des organismes concernés
- Collaborer à l'échelle nationale et internationale pour prévenir et gérer les incidents majeurs

CERT

CERT signifie "Computer Emergency Response Team".

- En 1988, le CERT Coordination Center a été créé à l'Université Carnegie Mellon pour faire suite à l'attaque du ver Morris
- Cette initiative visait à centraliser la gestion des incidents de cybersécurité et à coordonner les réponses techniques
- Le terme "CERT" a été utilisé pour la première fois pour désigner cette équipe pionnière
- Il symbolise l'approche initiale de réponse aux urgences en sécurité informatique adoptée par cette structure

L'expérience et les pratiques développées par le CERT Coordination Center ont servi de modèle et ont inspiré la création d'autres équipes de réponse aux incidents, conduisant à l'adoption plus large du terme et à l'évolution vers le terme "CSIRT" pour englober des missions plus étendues

CSIRT

CSIRT signifie "Computer Security Incident Response Team"

- C'est un terme générique désignant toute équipe dédiée à la gestion et à la réponse aux incidents de sécurité informatique
- CSIRT a été adopté par la suite pour décrire des équipes dont les responsabilités se sont élargies au-delà de la simple réaction d'urgence

Portée de la mission

Le terme CSIRT englobe souvent un champ d'action plus large incluant la prévention, la détection, la réponse et la remédiation des incidents, alors que CERT met davantage l'accent sur l'intervention d'urgence en cas de cyber incident

Usage et contexte

En pratique, les deux termes sont parfois utilisés de manière interchangeable, mais certaines organisations préfèrent "CSIRT" pour refléter une approche globale de la gestion des incidents, alors que "CERT" est utilisé pour désigner des entités nationales ou sectorielles ayant un mandat officiel de réponse aux crises cybernétiques

CERT-FR

Le CERT-FR est le centre gouvernemental français de veille, d'alerte et de réponse aux attaques informatiques.

Parmi ses missions, on peut citer :

- Il est rattaché à l'ANSSI (Agence Nationale de la Sécurité des Systèmes d'Information)
- Il assure la détection, l'analyse et le traitement des incidents ciblant les administrations, les entreprises et organismes d'importance vitale français
- Il publie des alertes, bulletins de sécurité et recommandations techniques accessibles publiquement sur son site web
- Il participe activement à la coopération internationale sur la cybersécurité, en collaborant avec d'autres CERT étrangers

Site officiel : <https://www.cert.ssi.gouv.fr/>



ALERTES DE SÉCURITÉ

Les alertes de sécurité sont des documents destinés à prévenir d'un danger immédiat

28 janvier 2025	CERTFR-2025-ALE-002	[Maj] Vulnérabilité dans les produits Fortinet	Alerte en cours
30 octobre 2024	CERTFR-2024-ALE-014	[Maj] Multiples vulnérabilités dans Fortinet FortiManager	Alerte en cours
09 janvier 2025	CERTFR-2025-ALE-001	[Maj] Vulnérabilité dans les produits Ivanti	Alerte en cours
22 octobre 2024	CERTFR-2024-ALE-013	Exploitations de vulnérabilités dans Ivanti Cloud Services Appliance (CSA)	Alerte en cours
15 novembre 2024	CERTFR-2024-ALE-015	[Maj] Multiples vulnérabilités sur l'interface d'administration des équipements Palo Alto Networks	Clôturée le 27/01/25

VOIR TOUTES LES ALERTES >>

En cas d'incident, les bons réflexes en cas d'intrusion sur un système d'information sont à retrouver [ici](#).

MENACES ET INCIDENTS

Les rapports Menaces et incidents détaillent l'état des connaissances et les investigations de l'ANSSI en analyse de la menace et traitements d'incidents

11 mars 2025	CERTFR-2025-CTI-004	GB Cyber Threat Overview 2024
11 mars 2025	CERTFR-2025-CTI-003	Panorama de la cybermenace 2024
24 février 2025	CERTFR-2025-CTI-002	Collectivités territoriales - Synthèse de la menace
20 février 2025	CERTFR-2025-CTI-001	Secteur du cloud - État de la menace informatique
28 novembre 2024	CERTFR-2024-CTI-011	Secteur de l'eau : état de la menace informatique

VOIR TOUTS LES RAPPORTS »

AVIS DE SÉCURITÉ

Les avis de sécurité sont des documents faisant état de vulnérabilités et des moyens de s'en prémunir

21 mars 2025	CERTFR-2025-AVI-0235	Multiples vulnérabilités dans le noyau Linux d'Ubuntu
21 mars 2025	CERTFR-2025-AVI-0234	Multiples vulnérabilités dans le noyau Linux de SUSE
21 mars 2025	CERTFR-2025-AVI-0233	Multiples vulnérabilités dans les produits IBM
21 mars 2025	CERTFR-2025-AVI-0232	Vulnérabilité dans Liferay
21 mars 2025	CERTFR-2025-AVI-0231	Vulnérabilité dans Microsoft Office
21 mars 2025	CERTFR-2025-AVI-0230	Vulnérabilité dans Tenable Nessus Agent
20 mars 2025	CERTFR-2025-AVI-0229	Vulnérabilité dans Veeam Backup & Replication

CERT-EU

Le CERT-EU est l'équipe d'intervention en cybersécurité dédiée aux institutions, agences et organes de l'Union Européenne.



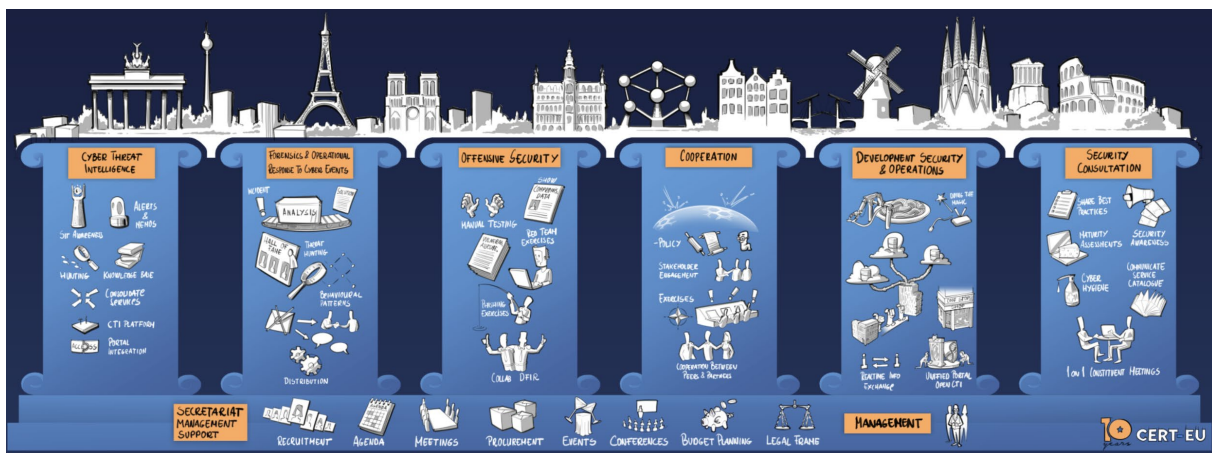
Parmi ses missions, on peut citer :

- Il protège les institutions européennes contre les incidents et cyberattaques, garantissant ainsi leur continuité opérationnelle
- Il diffuse des bulletins et recommandations en matière de cybersécurité auprès des entités européennes concernées
- Il coordonne les échanges d'information et coopère étroitement avec les CERT nationaux au sein de l'UE
- Il joue un rôle clé dans l'analyse des cybermenaces au niveau européen et dans l'amélioration de la résilience des infrastructures critiques européennes

Site officiel : <https://cert.europa.eu/>

Équipes du CERT-EU :

- CTI (Cyber Threat Intelligence)
- Forensics and Operational Response to Cyber Events
- Offensive Security
- DevSecOps
- Cooperation
- Security Consultation



VII. Normes et cadres de Référence

A. Normes ISO

ISO/IEC 27001 – Management de la sécurité

Norme internationale définissant les exigences pour la mise en œuvre d'un Système de Management de la Sécurité de l'Information (SMSI). Permet d'organiser la sécurité selon une approche d'amélioration continue (planifier, déployer, vérifier, améliorer).

ISO/IEC 27002 – Bonnes pratiques de sécurité

Référentiel international présentant des bonnes pratiques détaillées en cybersécurité. Complète ISO/IEC 27001 en proposant un ensemble de contrôles à appliquer selon les risques identifiés dans l'organisation.

ISO/IEC 27005 – Gestion des risques de sécurité

Norme définissant les méthodes de gestion des risques liés à la sécurité de l'information. Propose des étapes concrètes pour identifier, évaluer, traiter et suivre les risques de sécurité au sein d'une organisation.

ISO/IEC 27701 – Gestion des données personnelles

Norme complémentaire à ISO/IEC 27001 dédiée à la gestion des données personnelles. Permet aux organisations de démontrer leur conformité au RGPD, en intégrant explicitement les exigences relatives à la protection des données personnelles.

B. Cadres et réglementations européens

RGPD (Règlement Général sur la Protection des Données)

Règlement européen obligatoire encadrant la collecte, le traitement et la gestion des données personnelles. Renforce les droits des citoyens européens concernant l'utilisation de leurs données (consentement explicite, droit à l'oubli, portabilité, notification des violations)

Directive NIS 2

Directive européenne actualisant et renforçant les obligations en cybersécurité des entreprises et organisations de l'UE. Élargit le périmètre des secteurs concernés, renforce les exigences de notification des incidents et introduit une responsabilisation accrue des dirigeants.

Règlement DORA (Digital Operational Resilience Act)

Réglementation européenne axée sur la résilience numérique du secteur financier. Impose des exigences spécifiques aux banques et institutions financières en matière de cybersécurité, de gestion des risques et de réponse aux incidents.

Cybersecurity Act

Règlement européen instaurant un cadre harmonisé de certification pour les produits, processus et services numériques (produits et services TIC). Renforce la confiance numérique en permettant aux entreprises et consommateurs de mieux évaluer la sécurité des technologies numériques utilisées.

IA Act (Artificial Intelligence Act)

Règlement européen destiné à encadrer l'utilisation de l'intelligence artificielle au sein de l'Union Européenne. Introduit une classification des systèmes d'IA selon les risques (interdits, à haut risque, encadrés ou non réglementés) et impose des exigences spécifiques aux systèmes à haut risque (transparence, sécurité, gouvernance des données et supervision humaine).

Vise à garantir une IA éthique, responsable et respectueuse des droits fondamentaux des citoyens européens.

C. Cadres et réglementations internationaux

NIST Cybersecurity Framework (États-Unis)

Cadre américain développé par le National Institute of Standards and Technology (NIST).

Ce cadre propose une approche structurée (Identifier, Protéger, Détecter, Répondre, Restaurer) pour renforcer la résilience des systèmes face aux cybermenaces. Il est très utilisé à l'international pour organiser la gestion des risques cyber

CIS Controls (Center for Internet Security)

Référentiel américain de bonnes pratiques en cybersécurité, élaboré par le CIS.

Ce référentiel comprend 18 contrôles critiques permettant aux organisations de prioriser efficacement les mesures de protection contre les cyberattaques.

Les benchmarks du CIS du Center of Internet Security (CIS) sont reconnus mondialement et font l'objet d'un consensus. Il s'agit d'un ensemble de bonnes pratiques visant à aider les professionnels de la sécurité mais également les équipes techniques à mettre à renforcer leurs défenses en matière de cybersécurité, notamment par le biais du durcissement (hardening) des systèmes et des équipements afin de limiter leurs vulnérabilités.

PCI-DSS (Payment Card Industry Data Security Standard)

Standard international créé par les grands acteurs de cartes bancaires (Visa, MasterCard, American Express...). Définit des exigences techniques et opérationnelles précises afin d'assurer la sécurité des paiements par carte bancaire.

VIII. Métiers de la Cybersécurité

La Cybersécurité est un domaine large se décomposant globalement en trois sous-ensembles :

- Sécurité Défensive
- Sécurité Offensive
- GRC (Gouvernance, Risques et Conformité)

Ces sous-domaines sont complémentaires et permettent de mettre en œuvre une approche globale pour protéger les systèmes d'information d'une entreprise. Ils impliquent à la fois des compétences techniques, organisationnelles et juridiques.



A. Métiers de la Sécurité Défensive



Le volet défensif de la sécurité consiste à mettre en œuvre l'ensemble des mesures techniques et organisationnelles visant à protéger efficacement les infrastructures informatiques.

Il repose sur la capacité à détecter rapidement les incidents, prévenir les menaces potentielles et répondre efficacement aux incidents avérés, afin d'assurer la continuité des services et limiter les impacts sur l'organisation.

Ce domaine regroupe plusieurs spécialités et métiers aux compétences variées et complémentaires.

Consultant en Cybersécurité

La mission du consultant en Cybersécurité consiste à accompagner les organisations dans l'évaluation et l'amélioration de leur posture de cybersécurité.

Responsabilités :

- Réaliser audits et évaluations des risques cyber
- Proposer et implémenter des solutions de sécurité adaptées
- Sensibiliser et former les collaborateurs aux bonnes pratiques de sécurité

Compétences requises : Analyse de risques, forte expertise technique, qualités pédagogiques



Ingénieur Sécurité



La mission de l'ingénieur sécurité consiste à concevoir, implémenter et maintenir des solutions de sécurité informatique au sein des organisations.

Responsabilités :

- Installer et configurer des équipements et solutions de sécurité (Pare-feu, Proxy, VPN, IDS/IPS, EDR, Antivirus, SIEM...)
- Gérer la maintenance et l'évolution des systèmes de sécurité
- Réaliser régulièrement des tests et audits de sécurité
- Documenter et maintenir à jour les procédures techniques et opérationnelles

Compétences requises : Réseaux, protocoles de sécurité, maîtrise des systèmes Linux et Windows, scripting, maîtrise des solutions de sécurité

Analyste SOC / Blue Team Operator

La mission de l'analyste SOC ou de l'opérateur Blue-Team consiste à surveiller continuellement les infrastructures afin de détecter rapidement les incidents de sécurité.

Responsabilités :

- Effectuer une surveillance active et analyser les journaux systèmes et alertes sécurité
- Exploiter et améliorer les capacité de détection des différents outils
 - SIEM
 - IDS/IPS
 - EDR
- Identifier, catégoriser et escalader les incidents selon leur criticité
- Participer activement à la gestion et à la réponse aux incidents
- Assurer une veille cyber permanente et mettre à jour les bases de Cyber Threat Intelligence (CTI)
- Élaborer des rapports périodiques à destination des équipes stratégiques

Compétences requises : SIEM (Splunk, ELK, Wazuh), connaissances des cybermenaces, scripting (Python, Bash), capacité d'analyse rapide



Architecte Sécurité



La mission de l'architecte sécurité consiste à concevoir des architectures informatiques sécurisées et résilientes contre les cyberattaques.

Responsabilités :

- Élaborer des architectures sécurisées pour les infrastructures réseaux, applicatives et cloud
- Évaluer et valider la robustesse des solutions déployées
- Collaborer étroitement avec les équipes de développement et IT pour intégrer la sécurité dès les premières étapes des projets
- Rédiger les politiques et procédures techniques

Compétences requises : Expertise en sécurité réseau, conception d'infrastructures robustes, analyse approfondie des risques

Incident Responder (Réponse à Incidents)



La mission de l'incident responder consiste à assurer une réponse rapide et efficace en cas d'incidents de cybersécurité.

Responsabilités :

- Analyser les incidents
- Identifier les sources et vecteurs d'attaque
- Contenir, éradiquer et restaurer les systèmes compromis
- Proposer et appliquer des mesures correctives et préventives
- Coordonner la réponse avec les acteurs internes et externes
- Contribuer à la rédaction de rapports d'incidents détaillés

Compétences requises : Investigation numérique, analyse de malware, procédures d'Incident Response, capacité à gérer les crises

Analyste Forensic



Sa mission : Enquêter sur les cyber-incidents pour identifier les causes et impacts précis

Responsabilités :

- Collecter et préserver les preuves numériques
- Reconstruire les scénarios d'attaque pour en comprendre les mécanismes
- Soutenir les enquêtes judiciaires par l'apport de preuves techniques

Compétences requises : Investigation numérique, gestion rigoureuse des preuves, outils spécialisés forensic, curiosité

Analyste CTI (Cyber Threat Intelligence)

La mission de l'analyste CTI consiste à collecter et analyser les informations concernant les cybermenaces actuelles et émergentes

Responsabilités :

- Surveiller les activités des groupes cybercriminels et APT
- Analyser et interpréter les tendances et vecteurs d'attaque
- Informer et communiquer efficacement les résultats aux équipes opérationnelles
- Gérer et maintenir les bases d'IOC (Indicators of Compromise)



Compétences requises : OSINT, analyse approfondie des malware, compréhension globale des menaces cyber, analyse des groupes APT, maîtrise des frameworks MITRE ATT&CK et D3FEND

B. Métiers de la Sécurité Offensive



Le volet offensif de la cybersécurité regroupe l'ensemble des activités, outils et techniques permettant d'identifier et d'exploiter les failles et vulnérabilités présentes au sein des infrastructures, systèmes et applications.

L'objectif est de simuler des attaques informatiques réalistes afin d'évaluer la résistance et la robustesse des dispositifs de sécurité en place, en vue de renforcer leur protection.

Ce domaine comporte plusieurs métiers et spécialités aux compétences spécifiques et variées.

Pentester (Testeur d'Intrusion)

La mission d'un pentester est d'identifier et d'exploiter les vulnérabilités dans les systèmes, réseaux et applications d'une entreprise et ce, dans un cadre légal.

La légalité de son intervention repose sur l'établissement d'un contrat précisant la portée (scope) et les outils autorisés durant la phase de pentest.

À l'issue de ses tests, le pentester rédige un rapport et le présente au client.

Responsabilités :

- Réaliser des tests d'intrusion sous différentes formes
 - Black-box : aucune information préalable sur la cible (système, réseau, application...)
 - Grey-box : informations partielles mais limitées (adresses IP, schémas réseau partiels, comptes utilisateurs standards)
 - White-box : accès complet à la documentation technique, code source, informations détaillées du système
- Rédiger des rapports techniques précis et détaillés
- Proposer des recommandations et des actions correctives

Compétences requises : connaissance des différents systèmes d'exploitation, Réseau, Web, exploitation à l'aide d'outils tels que Metasploit, Burp Suite, Nessus, analyse manuelle approfondie des vulnérabilités, capacités rédactionnelles



Red Team Operator



La mission d'un opérateur Red-Team est de réaliser dans un cadre légal des cyberattaques réalistes pour évaluer et renforcer la cybersécurité d'une organisation.

Responsabilités :

- Mener des interventions encadrées incluant ingénierie sociale, phishing, techniques d'évasion...
- Concevoir des outils d'attaque pour ses missions (exploits, serveurs C2...)
- Coordonner étroitement les actions avec la Blue Team
- Documenter précisément les scénarios et les résultats

Compétences requises : Techniques avancées de hacking, ingénierie sociale, outils d'attaque sophistiqués, capacités rédactionnelles

Purple Team Operator

Sa missions est de favoriser une coopération efficace entre les équipes offensives et défensives pour améliorer globalement la cybersécurité d'une organisation.

Responsabilités :

- Organiser et animer des exercices communs entre Red Team et Blue Team
- Analyser les résultats des tests d'intrusion et émettre des recommandations pour renforcer les défenses
- Assurer une communication efficace entre les équipes pour partager les meilleures pratiques

Compétences requises : Maîtrise des outils offensifs et défensifs, capacités de communication inter-équipes



Bug Bounty Hunter



La mission d'un Bug Bounty Hunter est d'identifier des vulnérabilités des infrastructures référencées sur des plateformes de bug bounty via des programmes dédiés.

Pour chaque vulnérabilité identifiée et exploitée, le hunter est susceptible d'obtenir une prime (bounty).

Cette activité doit bien entendu être effectuée dans un cadre légal. Différentes plateformes de bug bounty existent pour permettre de pratiquer cette activité. Généralement, le bug bounty hunter exerce cette activité en parallèle d'une autre activité professionnelle.

Responsabilités :

- Identifier et exploiter les failles web courantes (OWASP Top 10) mais également des failles plus particulières comme les failles de type « Business Logic »
- Soumettre des rapports détaillés aux plateformes concernées illustrant l'exploitation et l'impact
- Éventuellement assurer le suivi et la validation des correctifs proposés

Compétences requises : Techniques avancées de hacking, compréhension approfondie des failles web, capacités rédactionnelles

Vulnerability Researcher – Exploit Developer

Sa mission est de rechercher des vulnérabilités non découvertes sur des solutions informatiques et d'en informer les autorités compétentes. Dans le cadre de cet activité, il peut également développer des exploits et outils pour exploiter ces vulnérabilités spécifiques.

Responsabilités :

- Identifier, analyser et exploiter des vulnérabilités complexes non découvertes
- Développer des exploits personnalisés et des outils spécifiques
- Rédiger des rapports et les soumettre aux organismes comme le MITRE afin de référencer les failles connues (CVE)
- Tester la résistance des systèmes et logiciels aux exploits développés



Compétences requises : Programmation bas niveau (assembleur, C...), développement d'exploits avancés, connaissance approfondie des vulnérabilités

C. Métiers de la GRC



La GRC (Gouvernance, Risques et Conformité) regroupe l'ensemble des pratiques permettant à une organisation de garantir :

- L'élaboration et l'application d'une Politique de Sécurité des Systèmes d'Information (PSSI) claire et cohérente
- Une gestion optimale des risques liés à la cybersécurité
- La conformité aux exigences réglementaires et légales en vigueur

Il existe différents métiers et spécialités dans le domaine de la GRC.

RSSI (Responsable de la Sécurité des Systèmes d'Information)

Sa mission est de définir, mettre en œuvre et superviser la stratégie globale de sécurité informatique de l'organisation

Responsabilités :

- Définir les rôles, responsabilités et procédures liées à la cybersécurité
- Élaborer et piloter la Politique de Sécurité des Systèmes d'Information (PSSI) puis s'assurer de son application
- Définir et suivre des indicateurs clés de performance (KPI) pour évaluer l'efficacité des mesures de sécurité
- Gérer les risques cyber et assurer la conformité réglementaire (RGPD, ISO 27001)
- Coordonner et superviser les projets et équipes cybersécurité internes et externes
- Organiser des campagnes de sensibilisation et de formation à destination des utilisateurs
- Assurer la gestion proactive et réactive des incidents de sécurité



Compétences requises : Vision stratégique, compréhension approfondie des enjeux cybersécurité, capacité à coordonner différents services, gestion des risques, normes et cadres réglementaires (ISO, RGPD), leadership, communication stratégique,

Analyste risques en Cybersécurité – Risk Manager



Sa mission est d'identifier, évaluer et contrôler les risques pouvant impacter l'organisation, en particulier les risques liés à la cybersécurité

Responsabilités :

- Identifier les menaces et vulnérabilités potentielles
- Suivre les méthodologies d'analyse de risques (EBIOS RM, MEHARI...)
- Analyser les risques selon leur probabilité d'occurrence et leur impact potentiel
- Élaborer des plans de gestion des risques
- Suivre les évolutions des menaces et adapter les stratégies en conséquence

Profils types :

- Risk Manager : Élabore les stratégies globales de gestion des risques
- Analyste Risques : Conduit des analyses précises sur les risques opérationnels et cyber
- Risk Officer : Veille au respect des procédures de gestion des risques dans l'organisation

Compétences requises : Analyse et gestion des risques, connaissance des méthodologies d'évaluation des risques, capacité à anticiper

Auditeur conformité

Sa mission est d'assurer la conformité de l'organisation aux exigences réglementaires et normatives, notamment en matière de sécurité et de protection des données

Responsabilités :

- Identifier et suivre l'évolution des réglementations applicables
- Mettre en œuvre des procédures de conformité au sein de l'organisation
- Vérifier et auditer régulièrement la conformité des processus internes
- Conseiller et accompagner les équipes internes sur les problématiques de conformité



Profils types :

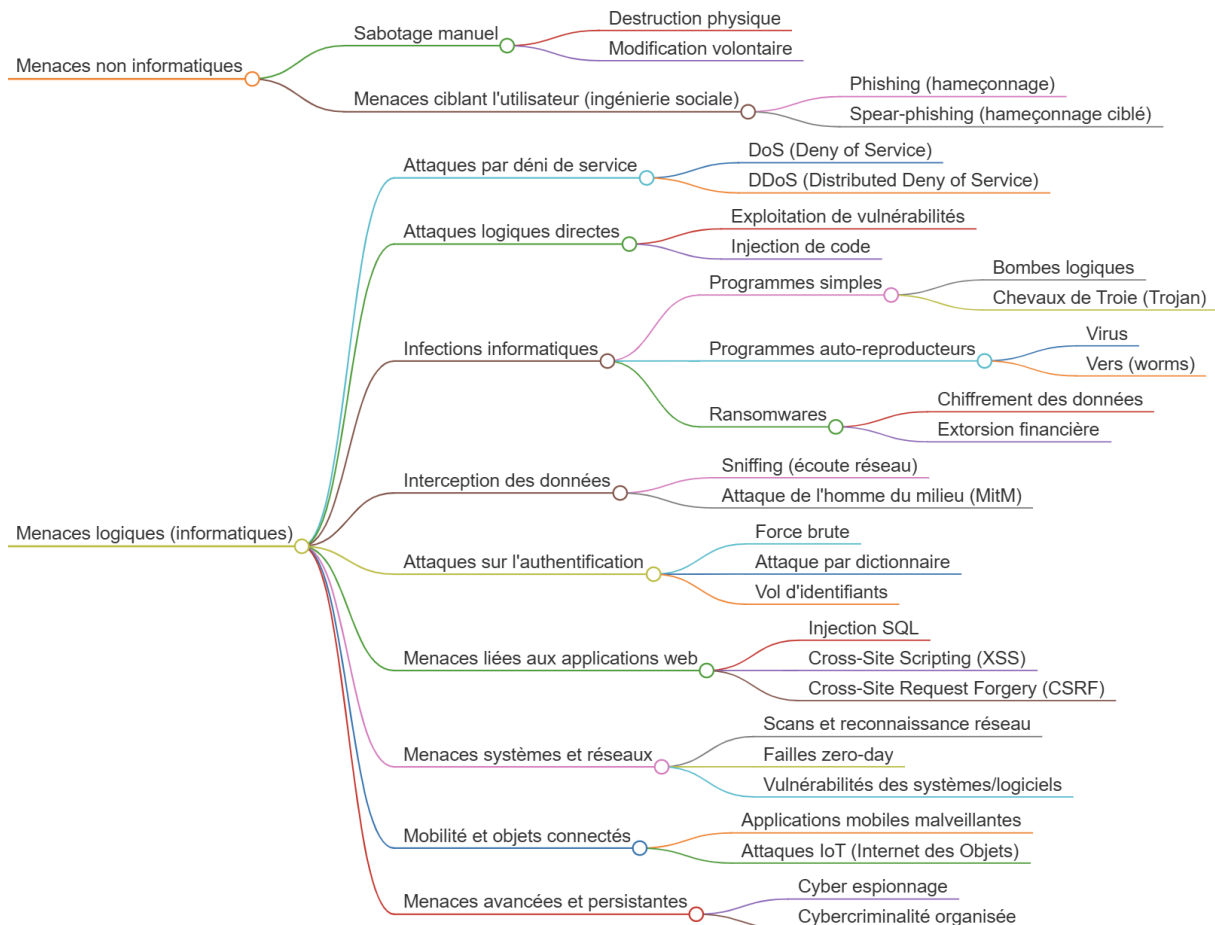
- Chief Compliance Officer : Pilote la stratégie globale de conformité réglementaire
- Auditeur Interne : Réalise des audits réguliers pour vérifier la conformité interne
- Conseiller Conformité : Fournit des conseils et recommandations sur l'application des normes et réglementations

Compétences requises : Connaissance approfondie des réglementations sectorielles, rigueur, sens du détail, capacité d'accompagnement

Menaces informatiques

I. Généralités

Les manières d'attaquer un système informatique sont multiples, elles peuvent être de différentes natures : non informatique ou bien logiques (liste non exhaustive).



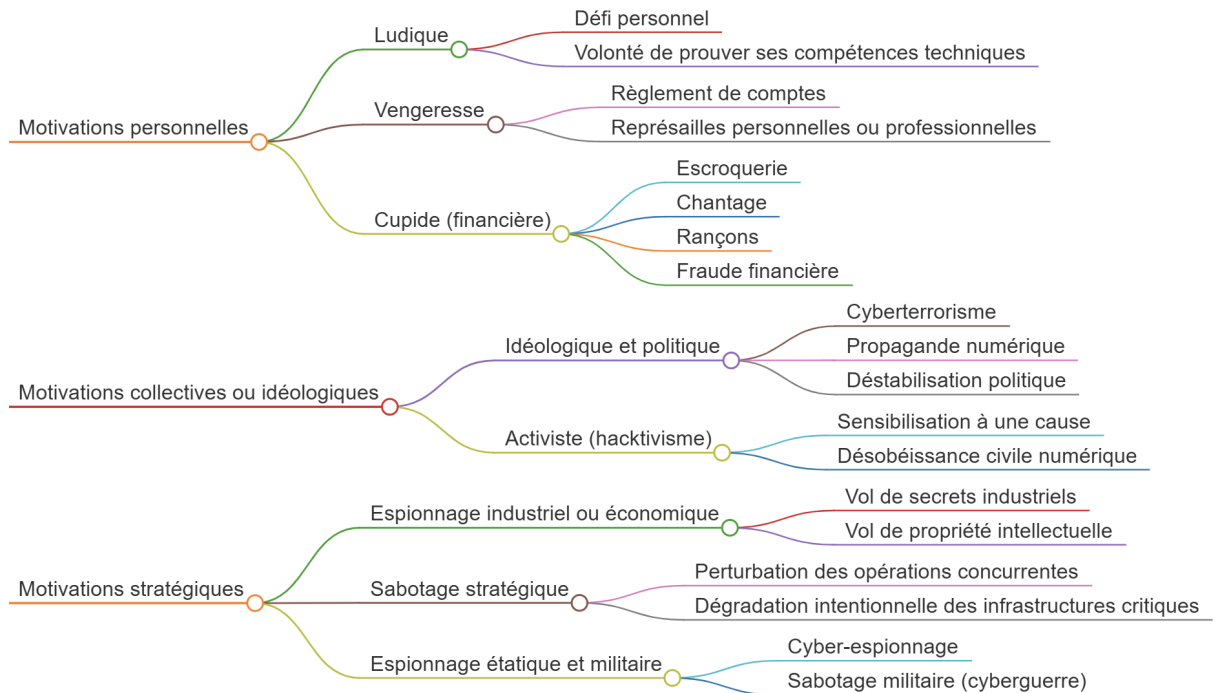
A. Infections informatiques

Une infection informatique est un programme simple ou autoreproducteur, s'installant sur un système d'information, à l'insu du ou des utilisateurs, en vue de porter atteinte à la confidentialité, à l'intégrité ou à la disponibilité de ce système ou des données de ce système, et éventuellement susceptible d'incriminer à tort son possesseur ou l'utilisateur dans la réalisation d'un crime ou d'un délit.

Les infections informatiques sont de nature logique et ne sont qu'une partie des malveillances possibles. De nos jours, de nombreuses attaques peuvent combiner plusieurs catégories de codes malveillants et/ou de mesures non informatiques.

B. Motivations des attaquants

Les motivations des attaquants sont diverses et variées.



Très souvent, certaines de ces motivations tendent à se cumuler...

C. Types de programmes malveillants

Fonctions logicielles

De nombreuses fonctions sont utilisées dans les programmes, qu'il s'agisse de programmes classiques ou de programmes infectieux.

Les principales fonctions sont les suivantes :

- **Fonction licite** : les fonctions licites constituent la grande part d'un logiciel. Elles lui permettent de faire ce pour quoi il a été construit. Il existe cependant souvent une petite part de fonctions cachées, permettant au logiciel d'exécuter des fonctions, des programmes non prévus (jeux par exemple...) mais pouvant également être malveillantes.
- **Fonction cachée** : fonction non autorisée d'un programme. Non documentée, elle ne concourt pas aux objectifs du programme. Si l'utilisateur connaît la manière de l'activer, il peut l'utiliser.
- **Fonction illicite** : une fonction cachée offrant des fonctionnalités le plus souvent illégales.
- **Fonction de déplacement** : fonction d'un programme qui est capable de transférer un programme en cours d'exécution. Ces fonctions sont très utilisées par les codes malicieux afin de détourner des processus de leur utilisation légitime.
- **Fonction de déclenchement différée** : mise en attente d'une condition pour exécuter le programme comme par exemple, les gâchettes des bombes logiques.
- **Fonction d'autoreproduction** : permet de créer une réplique identique de lui-même ou du programme.

Programme simple

Les programmes simples sont des programmes s'installant sur le système cible et ne se propagent pas par eux-mêmes.

Programme autoreproducteur

Les programmes autoreproducteurs sont des programmes qui peuvent recopier leur propre code et propager ainsi l'infection.

Les programmes autoreproducteurs sont de deux types : les virus et les vers.

- Le virus a pour objectif de se reproduire au sein du système infecté
- Le ver, quant à lui, peut se déplacer à travers un réseau par ses propres moyens

Bombe logique

Ces dispositifs programmés sont déclenchés à un moment déterminé en exploitant la date du système, le lancement d'une commande, ou n'importe quel appel au système.

D.Catégories de malwares

Ce type de logiciel malveillant également appelé maliciel, logiciel nuisible, programme malveillant ou pourriel est un programme développé afin de nuire à un système informatique, sans le consentement de l'utilisateur dont le système est infecté.

Terme générique pour désigner l'ensemble des logiciels malveillants (virus, vers, chevaux, bombes logiques...).



Spyware

Il s'agit d'un type de malware utilisé afin de collecter des informations concernant l'utilisateur cible (données personnelles, informations d'authentification, habitudes, copie des frappes clavier...).

Adware

Logiciel publicitaire ou publiciel affichant de la publicité lors de son utilisation. Il contient habituellement deux parties : une partie utile qui incite un utilisateur à l'installer sur son ordinateur et une partie qui gère l'affichage de la publicité.



Scareware



Logiciel malveillant ou application frauduleuse qui tente de faire peur à l'utilisateur en affichant de faux messages d'alerte (ex : virus détecté, erreurs système critiques) dans le but de le pousser à acheter un faux antivirus, installer un programme malveillant ou divulguer des informations personnelles.

Le scareware joue sur l'urgence et l'anxiété pour manipuler la victime.

Wiper

Malware conçu pour détruire les données d'un système cible. Contrairement aux ransomwares, le but n'est pas de monnayer la récupération des fichiers, mais de nuire, saboter ou effacer toute trace (fichiers, partitions, MBR) de manière définitive.

Il est souvent utilisé dans des contextes de cyberguerre ou d'attaques ciblées contre des infrastructures critiques.



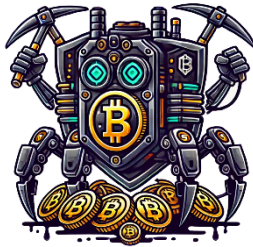
Ransomware

Malware ayant pour objectif de chiffrer tout ou partie du système de fichier de la machine victime, le plus souvent pour exiger une rançon auprès de l'entreprise victime.

L'attaque par ransomware (ou crypto-locker) est le type d'attaque le plus emblématique de notre époque.



Crypto-miner



Logiciel malveillant qui exploite les ressources d'un système (CPU/GPU) pour miner des cryptomonnaies à l'insu de l'utilisateur. Il peut s'introduire via un malware ou une extension web, et entraîne souvent un ralentissement notable du système, une surchauffe des composants et une consommation excessive d'énergie.

L'attaquant encaisse les gains pendant que la victime subit les conséquences.

Virus informatique

Un virus est un programme se propageant par recopie de son propre code dans des cibles préalablement choisies.

Un virus infectera les fichiers pour lesquels il a été conçu mais ne sortira pas de lui-même du système infecté.

Il existe différents types de virus :

- Virus d'exécutable (fichier binaire infecté chargé d'infecter les autres fichiers binaires)
- Virus de document (souvent intégré dans les macros)
- Virus de démarrage : visant à attaquer les programmes de démarrage comme le BIOS le MBR ou autre



Ver informatique

Un ver informatique est un programme autoreproducteur capable de propager une infection à travers un réseau sans être nécessairement attaché à un fichier pour se propager.

Un ver est doté de la faculté de se déplacer et de se reproduire au sein d'un réseau ou des périphériques connectés à un système.

Il existe différents types de vers :

- Vers simples (exploitation de failles ou des faiblesses des protocoles réseau)
- Vers de macro (évolution du virus de document)
- Vers d'email (contenu dans une pièce-jointe)



Cheval de Troie (Trojan)



Ce type de logiciel malveillant ne doit pas être confondu avec les virus et les vers.

En apparence légitime le cheval de troie contient une fonctionnalité malveillante. Son but est de faire pénétrer cette fonctionnalité malveillante sur la cible et de l'exécuter l'insu de l'utilisateur.

Ceci permet à l'assaillant de s'ouvrir une « backdoor » au sein du système cible et de pouvoir ensuite exploiter cette porte d'entrée afin de causer les méfaits souhaités (accès à des informations confidentielles, destruction/sabotage de donnée ou de l'infrastructure, modification des configurations pour s'accorder davantage de privilèges...).

Le cheval de Troie est un programme simple composé de 2 parties :

- Un module serveur, installé dans la machine de la victime pour donner à l'attaquant accès à tout ou partie de ses ressources
- Un module client qui permet à l'attaquant d'accéder, via le réseau, aux ressources mises à sa disposition par le module serveur. (L'attaquant est le client des services proposés par la victime)

Logic bomb

Code malveillant intégré discrètement dans un programme légitime, qui s'active uniquement lorsque certaines conditions spécifiques sont remplies (date, action utilisateur, connexion réseau, etc.).

Une fois déclenchée, elle peut supprimer des fichiers, chiffrer des données ou causer des dysfonctionnements. Elle est souvent utilisée pour saboter un système à distance ou réaliser une action malveillante programmée (utilisation de tâches planifiées).



Rooktit



Malware conçu pour masquer la présence d'autres malwares ou activités malveillantes en modifiant le fonctionnement du système d'exploitation (fichiers système, processus, registres, etc.). Il permet à un attaquant de maintenir un accès furtif et prolongé à un système compromis, souvent avec des privilèges élevés (root/admin). Très difficile à détecter et à supprimer.

Le Bootkit est une variante du rootkit qui infecte le secteur de démarrage (MBR/UEFI) d'un système. Il s'exécute avant le chargement du système d'exploitation, ce qui lui permet de bypasser les solutions de sécurité traditionnelles. Il offre un contrôle total du système dès le boot, ce qui le rend extrêmement dangereux et persistant.

Keylogger

Logiciel ou dispositif malveillant conçu pour enregistrer en secret les frappes clavier d'un utilisateur. Il permet de collecter des informations sensibles comme des identifiants, mots de passe, messages, ou numéros de carte bancaire.

Il peut fonctionner en mode logiciel (furtif) ou matériel (branché entre le clavier et l'ordinateur), et est souvent utilisé pour l'espionnage ou le vol de données.



Botnet



Réseau de machines compromises (appelées bots ou zombies) contrôlées à distance par un attaquant via un serveur de commande et de contrôle (C&C).

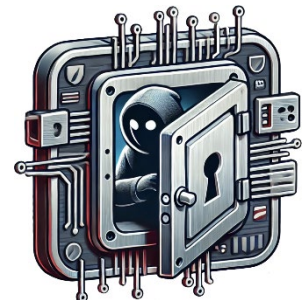
Les machines infectées peuvent être utilisées à l'insu de leurs propriétaires pour lancer des attaques DDoS, envoyer du spam, miner des cryptomonnaies, ou voler des données.

Le réseau de botnets agit comme une armée de machines zombies pilotées en masse. Un tel type de réseau est très difficile à démanteler.

Backdoor

Mécanisme volontairement ou malicieusement intégré à un système, logiciel ou service permettant à un attaquant d'accéder au système à distance, en contournant les mécanismes d'authentification classiques.

Elle peut être installée par un malware ou introduite intentionnellement par un développeur malveillant. Elle permet un accès furtif, persistant et discret pour voler des données, exécuter des commandes ou modifier la configuration du système.



Exploit Kit



Outil automatisé utilisé par les cybercriminels ou les professionnels de la sécurité offensive pour scanner un système à la recherche de vulnérabilités connues (navigateur, plugins, OS, etc.) et exécuter automatiquement des attaques (gain d'accès initial, ouverture de backdoor, escalade de privilèges...).

II. Reconnaissance passive

Phase initiale d'acquisition d'informations sur la cible effectuée « sans risque » de détection (pas d'interaction directe avec la cible).



A. Informations cibles

Vise à collecter des informations générales concernant la cible :

- Nom de l'entreprise, site web
- Prénoms, noms des employés
- Adresses IP, noms de domaine
- Adresses mails, numéros de téléphone

B. Sources d'information

- Consultation des bases de données publiques
 - WHOIS (propriétaires de domaines)
 - Registres DNS publics
 - Certificats SSL/TLS (Transparency logs)
- Recherche DNS passive
 - DNS history (historique des domaines)
 - Reverse DNS lookup
 - DNSdumpster, SecurityTrails
- Analyse des métadonnées
 - Métadonnées dans les fichiers (documents, images)
 - ExifTool, FOCA
- Utilisation des moteurs de recherche spécialisés
 - Shodan (scanneurs passifs)
 - Censys
 - GreyNoise (collecte de bruits réseau)
- Analyse des archives Internet
 - Wayback Machine (Internet Archive)
 - Sites de sauvegarde automatique
- Analyse passive du trafic réseau
 - Écoute silencieuse du réseau sans interaction (sur réseaux internes)
 - Captures passives Wi-Fi

C. OSINT (Open Source Intelligence)

La collecte OSINT consiste à recueillir des informations provenant exclusivement de sources publiques, accessibles librement.



Objectifs principaux

- Identifier des informations sensibles potentiellement exposées
- Recueillir des renseignements détaillés sur une cible (individu, entreprise, organisation)
- Déceler des points d'entrée possibles en préparation d'une attaque ou d'un audit
- Réduire la surface d'exposition pour renforcer la sécurité proactive

Avantages de l'OSINT

- Discrétion totale, sans interaction directe avec la cible
- Accès à des informations publiques gratuites et facilement disponibles
- Collecte rapide, sans risque d'alerter ou de déclencher des mécanismes de défense chez la cible

Sources de renseignement

- Sites web publics
- Réseaux sociaux (LinkedIn, Twitter, Facebook, Instagram, etc.)
- Médias en ligne (actualités, blogs, forums)
- Bases de données publiques (WHOIS, registre des entreprises)
- Outils spécialisés (Google Dorks, Maltego, SpiderFoot, TheHarvester, etc.)
- Moteurs de recherche avancés (Google, Bing, DuckDuckGo)
- Archives internet (Wayback Machine)
- Sources gouvernementales (OpenData)

III. Reconnaissance Active

Phase d'acquisition d'informations sur la cible nécessitant des interactions directes avec la cible ce qui implique un risque de détection.

A. Ingénierie sociale (social engineering)



Technique de manipulation psychologique visant à tromper une personne pour qu'elle divulgue volontairement des informations sensibles (identifiants, mots de passe, accès physiques, etc.) ou effectue une action compromettante (ouvrir une pièce jointe, cliquer sur un lien, brancher une clé USB).

Elle repose sur l'exploitation des émotions humaines (peur, confiance, curiosité, urgence) plutôt que sur des failles techniques. C'est l'une des méthodes les plus utilisées en cybersécurité, car l'humain reste souvent le maillon faible du système.

Les attaques informatiques comportent très souvent une part plus ou moins importante d'ingénierie sociale, c'est-à-dire l'utilisation des mauvaises habitudes, des biais cognitifs ou de la naïveté de l'utilisateur. Il s'agit d'un art : celui de la manipulation.

Il peut également s'agir de programmes visant à infecter le système et pouvant prendre pour cela une forme anodine et attractive (copie d'un site web d'apparence légitime, jeux, animation flash, copies illicites de logiciels, mails racoleurs...) avec comme but d'inciter la victime à exécuter ce programme ou à se connecter pour permettre ainsi l'infection (installation et propagation) ou bien le vol d'information sensibles (credentials, codes, numéros de carte bleu...).

Arnaque au président

Attaque d'ingénierie sociale consistant à se faire passer pour un cadre dirigeant, user du sentiment d'urgence et/ou des émotions pour obtenir l'exécution d'une action critique de la part de la victime (octroiement de privilèges administratif, virement bancaire...).



B. Écoute (sniffing)



Avant de nuire véritablement à sa victime, le pirate procède d'abord à une phase de renseignement. L'écoute réseau et le sondage s'inscrivent dans cette phase.

L'écoute réseau (sniffing) permet à une personne malveillante placée sur un brin du réseau de lire ou de capturer le trafic binaire transitant sur le réseau.

Cette première attaque, si elle est bien menée, est totalement passive : elle ne perturbe pas le fonctionnement du réseau et passe donc généralement inaperçue.

C. Scan



Le scan réseau est une technique utilisée pour collecter des informations sur un système ou un réseau cible, dans le but d'en dresser une cartographie, d'identifier les services actifs et de détecter les vulnérabilités potentielles.

Cette phase est essentielle en période de reconnaissance lors d'un audit de sécurité, d'un pentest ou d'une attaque malveillante.

Il existe différents types de scans.

Scan d'hôtes

- Recherche des machines actives sur un réseau (ex : ping sweep)
- Permet de détecter les adresses IP joignables et potentiellement exploitables

Scan de ports

- Interroge chaque hôte pour déterminer ses ports ouverts
- Les informations obtenues permettent de déduire les services en écoute (HTTP, FTP, SSH, etc.)
- Il est aussi possible d'obtenir les versions des systèmes d'exploitation et des logiciels installés afin de pouvoir ensuite les exploiter avec des vulnérabilités connues (CVE)

Scan de vulnérabilités

- Analyse les hôtes et services pour identifier des failles connues
- Compare les versions des systèmes/applications avec des bases de données de vulnérabilités (CVE)
- Permet à l'attaquant ou à l'auditeur de détecter des faiblesses de configuration ou de sécurité

Nmap

Nmap est l'outil de référence pour les scans réseau.

```
(root@KALI)-[~]
# nmap -sV 10.9.5.201
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-23 17:08 CET
Nmap scan report for 10.9.5.201
Host is up (0.00051s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE        VERSION
21/tcp    open  ftp            vsftpd 2.3.4
22/tcp    open  ssh            OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet        Linux telnetd
25/tcp    open  smtp          Postfix smtpd
53/tcp    open  domain        ISC BIND 9.4.2
80/tcp    open  http          Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind       2 (RPC #100000)
139/tcp   open  netbios-ssn   Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn   Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec          netkit-rsh rshd
513/tcp   open  login         OpenBSD or Solaris rlogind
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi      GNU Classpath grmiregistry
1524/tcp  open  bindshell     Metasploitable root shell
2049/tcp  open  nfs           2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql    PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc           VNC (protocol 3.3)
6000/tcp  open  X11          (Access denied)
6667/tcp  open  irc          UnrealIRCd
8080/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.52 seconds
```

IV. Types d'attaques principaux

Les gains d'accès initiaux désignent les techniques utilisées par un attaquant pour pénétrer une première fois dans un système ou un réseau cible. Cette phase marque le point d'entrée de l'attaque, souvent via l'exploitation d'une faille humaine, logicielle ou réseau.

Elle permet à l'attaquant de poser un premier pied, sous forme d'accès limité ou furtif. Cet accès servira de tremplin vers d'autres actions, comme l'escalade de privilèges, le mouvement latéral ou l'exfiltration de données. C'est une étape critique dans le cycle d'attaque, souvent difficile à détecter.

Il existe différents types d'attaques visant à obtenir des accès initiaux.

A. Phishing

Le phishing (hameçonnage en français) est une technique d'ingénierie sociale visant à tromper une victime pour lui voler des informations sensibles (identifiants, mots de passe, données bancaires) ou l'amener à exécuter une action compromettante (cliquer sur un lien vers un site frauduleux, ouvrir une pièce jointe contenant un malware...).

L'attaque consiste généralement à usurper l'identité d'une entité de confiance (banque, fournisseur d'accès, plateforme e-commerce, etc.) via un canal numérique comme l'e-mail, les SMS ou les appels téléphoniques. Il existe différentes catégories de phishing et certaines d'entre elles peuvent être combinées.

Spam

- Courriers indésirables non sollicités envoyés en masse à un grand nombre de destinataires
- La variante la plus malveillante du spam est connue sous le nom de MalSpam, car elle contient des malwares en pièce jointe ou via des liens

Phishing (classique)

- Courriers électroniques envoyés à une ou plusieurs cibles, prétendant provenir d'une entité de confiance
- Incite les destinataires à fournir des données sensibles ou à cliquer sur un lien malveillant
- Fait partie intégrante des attaques d'ingénierie sociale
- C'est la catégorie mère des autres formes de phishing



Spear Phishing

- Variante ciblée du phishing
- Vise des individus ou des organisations spécifiques (ex : un salarié d'une entreprise)
- Intervient obligatoirement après une phase de reconnaissance passive de collecte d'informations personnalisés concernant la cible pour renforcer la crédibilité (prénom, fonction, contexte, informations personnelles)

Whaling

- Forme de spear phishing qui cible spécifiquement des personnes haut placées
 - PDG
 - DAF
 - Cadres dirigeants
- But : réaliser des opérations critiques accéder à des informations stratégiques ou détourner des fonds



Smishing

- Contraction de "SMS" et "phishing"
- Envoi de SMS frauduleux pour inciter l'utilisateur à cliquer sur un lien ou à répondre avec des données sensibles
- Souvent inspiré de l'actualité (livraisons de colis, événements politiques, événements importants...)



Vishing

- Contraction de "voice" et "phishing"
- Utilise des appels téléphoniques pour tenter de soutirer des informations confidentielles
- Parfois automatisé (ex : faux service client)

Qishing

- Contraction de "QR code" et "phishing"
- L'attaquant diffuse un QR code malveillant (par affiche, flyer, mail, etc.)

Une fois scanné, il redirige la victime vers un site frauduleux imitant un service légitime pour voler des informations ou pousser au téléchargement d'un malware



B. USB Dropping



Technique d'ingénierie sociale consistant à déposer une/des clé(s) USB volontairement infectée(s) dans un lieu accessible à la cible (parking, salle de pause, ascenseur...).

L'objectif est que la victime, par curiosité ou négligence, branche la clé sur son poste, déclenchant ainsi l'exécution automatique d'un malware.

Ce dernier peut permettre à l'attaquant de prendre le contrôle du système, d'exfiltrer des données ou d'installer un accès persistant. Cette méthode exploite la faiblesse humaine plutôt qu'une faille technique. Elle reste efficace dans des environnements peu sensibilisés à la sécurité.

C. Téléchargements malveillants



Les téléchargements malveillants permettent à un attaquant de tromper la victime pour qu'elle installe elle-même un logiciel malveillant, ou d'exploiter une faille dans le navigateur pour installer un malware à son insu. Cette méthode repose souvent sur l'ingénierie sociale ou des failles web.

Il existe de nombreuses méthodes pour arriver à ce but.

Trojan

L'utilisateur télécharge puis installe un logiciel, une application ou un jeu vidéo sur un site douteux. Lors de l'exécution du fichier téléchargé, la charge malveillante s'active et effectue des opérations sur le système de la victime (ouverture de backdoor, installation de malware, chiffrement du disque, destruction des données...)

Drive-by Download

Télécharge et exécute automatiquement une charge malveillante lors de la visite d'un site compromis en exploitant des vulnérabilités dans le navigateur ou ses plugins. Cette technique est redoutable car elle ne nécessite aucune action de l'utilisateur.

Document piégé (malicious document)

Fichier Office ou PDF contenant du code malveillant (macro, script, exploit de vulnérabilité) généralement envoyé par email, téléchargé sur un site ou via un service cloud. La charge malveillante contenue dans le code est exécutée à l'ouverture du document.

Steganographie (contenu dissimulé)

La charge malveillante est dissimulée dans une image, une vidéo ou un fichier audio téléchargé sur un site douteux. Une fois téléchargé, un loader ou script extrait et exécute le code malveillant.

D.Spoofing



Le spoofing est une technique d'usurpation d'identité numérique qui consiste à se faire passer pour une autre entité (personne, machine, adresse IP, etc.) afin de tromper le système cible ou les utilisateurs.

Cette méthode est utilisée dans divers types d'attaques pour contourner des mécanismes de sécurité, collecter des données, ou établir une connexion non autorisée.

Il existe différents types de spoofing. Ces techniques sont utilisées pour d'autres attaques comme le MITM, la capture de paquets, le vol de session l'installation de malwares...

ARP Spoofing / ARP Poisoning

L'attaquant envoie de fausses entrées ARP sur le réseau local pour lier son adresse MAC à l'IP d'une autre machine. Le trafic destiné à une machine légitime (souvent la passerelle) est alors redirigé vers l'attaquant.

MAC Spoofing

L'attaquant falsifie son adresse MAC pour se faire passer pour une machine autorisée.

IP Spoofing

L'attaquant falsifie son adresse IP pour se faire passer pour une machine autorisée.

DHCP Spoofing

L'attaquant se fait passer pour un serveur DHCP pour fournir des adresses IP/pièges DNS/gateway falsifiés.

DNS Spoofing / DNS Poisoning

L'attaquant falsifie une réponse DNS ou corrompt un cache DNS pour rediriger une victime vers un faux site. Le nom de domaine saisi est correct, mais l'IP associée à ce nom lors de la résolution DNS pointe alors vers un serveur malveillant.

Email Spoofing

Usurpation de l'adresse de l'expéditeur dans un e-mail très utilisée dans les campagnes de phishing ou d'escroquerie (fraude au président). Cette technique peut permettre de tromper les utilisateurs si les protections SPF, DKIM, DMARC ne sont pas configurées.

E. Man-In-The-Middle (MITM Attack)



L'attaque MITM (Man-In-The-Middle), ou attaque de l'homme du milieu, est une technique où un attaquant s'intercale entre deux entités qui communiquent (deux humains, deux machines, ou un client et un serveur) afin d'intercepter, modifier ou rediriger les données échangées — sans que les victimes ne s'en rendent compte.

L'objectif est souvent de voler des informations sensibles (identifiants, données bancaires, sessions), mais l'attaquant peut aussi altérer les messages échangés ou injecter du contenu malveillant.

Conséquences possibles

- Vol d'identifiants et de mots de passe
- Détournement de sessions (session hijacking)
- Vol d'informations bancaires ou confidentielles
- Installation de malware à l'insu de la victime
- Altération de contenu dans les échanges (modification de message, d'IBAN, de pièces jointes...)

Scénarios typiques d'attaque MITM

- Un utilisateur se connecte à un site web via un Wi-Fi public non sécurisé ; l'attaquant intercepte les données échangées
- Un client envoie des identifiants de connexion à un serveur ; ils sont récupérés par l'attaquant en transit
- Un utilisateur croit dialoguer avec son interlocuteur habituel (collègue, fournisseur...), mais l'attaquant relaie et modifie les messages à son insu
- Une redirection DNS malveillante envoie l'utilisateur vers un faux site malgré l'URL correcte

Méthodes utilisées pour une attaque MITM

- Spoofing ARP (ARP poisoning) : l'attaquant falsifie les tables ARP pour se faire passer pour le routeur ou une autre machine sur le réseau local
- Spoofing DNS : falsification des réponses DNS pour rediriger la victime vers un site frauduleux
- Proxy transparent ou malveillant : l'attaquant agit comme un intermédiaire entre le client et le serveur
- Wi-Fi Rogue (point d'accès pirate) : l'attaquant crée un faux point d'accès Wi-Fi qui intercepte tout le trafic
- SSL stripping : suppression du chiffrement HTTPS pour forcer une communication en HTTP non sécurisé

F. Session hijacking (vol de session)

Le vol de session (ou session hijacking) est une technique d'attaque qui consiste pour un attaquant à usurper l'identité d'un utilisateur légitime auprès d'un serveur en récupérant un identifiant de session valide (cookie, token, jeton JWT, etc.).

Une fois en possession de cet identifiant, l'attaquant peut accéder aux ressources de l'application sans authentification, en profitant des droits et privilèges de la victime. Le serveur considère alors que l'attaquant est un utilisateur déjà connecté, ce qui court-circuite complètement les mécanismes de login.



Ce type d'attaque vise en priorité les comptes à privilèges élevés, comme les administrateurs, les utilisateurs avec accès à des données sensibles, ou ceux ayant des droits de configuration sur l'infrastructure. En compromettant une telle session, l'attaquant peut exfiltrer des données, modifier la configuration, voire prendre le contrôle total de l'application ou du système.

Il existe différentes techniques pouvant être utilisées pour du vol de session.

Interception et réutilisation de cookies

L'attaquant intercepte les cookies de session (par sniffing ou MITM) et les utilise pour se connecter à la place de la victime

Exploitation de failles comme le XSS ou le MITM

- Via une faille XSS (sur un site web généralement), l'attaquant injecte un script malveillant qui lui permet de voler le cookie de la victime.
- Via un MITM, l'attaquant intercepte les paquets contenant l'identifiant de session sur un réseau non sécurisé

Vol de token

- Utilisation d'un malware sur le poste de la victime pour extraire les tokens de session
- Sniffing réseau si les échanges ne sont pas chiffrés
- Exploitation de failles côté client, comme un navigateur mal configuré ou une extension vulnérable

G. Attaque bruteforce ou par dictionnaire

Bruteforce attack

Consiste à tester systématiquement toutes les combinaisons possibles pour trouver un mot de passe ou une clé afin de s'introduire dans un système, une machine ou de déchiffrer des données chiffrées.

En théorie cette attaque aboutit forcément à une réussite, seul le temps d'exécution varie. Le temps d'exécution est intimement lié avec la complexité du mot de passe ou bien l'algorithme de chiffrement utilisé, mais également avec la puissance de calcul de la machine d'attaque.



Dictionary attack



Similaire à l'attaque bruteforce mais réalisé en testant toutes les chaînes de caractère présentes dans un fichier de wordlist (dictionnaire) pour le login et/ou le mot de passe de la victime.

La célèbre wordlist rockyou.txt contient les mots de passes de la société éponyme RockYou (hackée en 2009). Lors de son attaque, la base de données contenant les noms et mots de passe en clair des 32 millions de clients de RockYou a été volée puis rendue publique.

Cette wordlist est souvent utilisée lors des attaques par dictionnaire.

```

kali@kali: ~/Desktop
File Actions Edit View Help
kali@kali: /etc/php/8.1/apache2 x kali@kali: ~/Desktop x

(kali@kali)-[~/Desktop]
$ hydra -l admin -P rockyou 127.0.0.1 http-post-form "/DVWA/vulnerabilities/brute/index.php:username=^USER^:password=^PASS^"
Hydra v9.3 (c) 2022 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for
es (this is non-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2023-05-17 04:07:16
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344401 login tries (l:1/p:14344401), ~896526 tries per task
[DATA] attacking http-post-form://127.0.0.1:80/DVWA/vulnerabilities/brute/index.php:username=^USER^:password=^PASS^
[80][http-post-form] host: 127.0.0.1 login: admin password: 12345
[80][http-post-form] host: 127.0.0.1 login: admin password: password
[80][http-post-form] host: 127.0.0.1 login: admin password: princess
[80][http-post-form] host: 127.0.0.1 login: admin password: 123456
[80][http-post-form] host: 127.0.0.1 login: admin password: 123456789
[80][http-post-form] host: 127.0.0.1 login: admin password: iloveyou
[80][http-post-form] host: 127.0.0.1 login: admin password: 1234567
[80][http-post-form] host: 127.0.0.1 login: admin password: rockyou
[80][http-post-form] host: 127.0.0.1 login: admin password: 12345678
[80][http-post-form] host: 127.0.0.1 login: admin password: abc123
[80][http-post-form] host: 127.0.0.1 login: admin password: daniel
[80][http-post-form] host: 127.0.0.1 login: admin password: monkey
[80][http-post-form] host: 127.0.0.1 login: admin password: nicole
[80][http-post-form] host: 127.0.0.1 login: admin password: babygirl
[80][http-post-form] host: 127.0.0.1 login: admin password: lovely
[80][http-post-form] host: 127.0.0.1 login: admin password: jessica
1 of 1 target successfully completed, 16 valid passwords found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2023-05-17 04:07:18

(kali@kali)-[~/Desktop]
$

```

H.Exploit



Un exploit ou code d'exploitation est, un élément type d'attaque utilisant un programme ou un script malveillant permettant d'exploiter une faille de sécurité d'un système ou d'un logiciel informatique.

Les vulnérabilités logicielles (« failles ») sont indépendantes de l'utilisateur. La bonne stratégie face à cela consiste à s'assurer de l'application des mises à jour de l'ensemble des éléments constitutifs du système d'informations (OS, logiciels, applications, protection antivirus...).

Il existe différentes catégories d'exploit.

Buffer OverFlow (débordement de tampon)

Consiste à faire exécuter un code arbitraire par un programme en lui envoyant plus de données qu'il n'est pas censé recevoir

Zero-Day Exploit

Exploitation d'une vulnérabilité inconnue ou non corrigée avant qu'un patch ou une solution ne soit disponible.

DLL Hijacking

Exploitation d'une application en remplaçant une bibliothèque dynamique (DLL) légitime par une DLL malveillante, souvent lors de son chargement

Kernel Exploits

Exploitation de vulnérabilités dans le noyau du système d'exploitation pour obtenir un accès total au système

Firmware Exploits

Attaques ciblant le firmware (logiciel bas-niveau) des appareils pour compromettre les systèmes embarqués, routeurs ou périphériques IoT. L'injection de code malveillant directement dans le firmware d'un appareil, peut permettre un accès persistant au matériel.

I. Attaques Web Client-Side



Les attaques Web côté client ciblent directement l'utilisateur ou son navigateur, en exploitant des failles dans le rendu ou l'interprétation du contenu web (HTML, JavaScript, plugins, extensions, etc.).

Elles consistent à injecter ou manipuler du contenu malveillant qui sera interprété sur le poste de la victime, souvent à son insu.

L'objectif est de voler des données sensibles (cookies, sessions, mots de passe), rediriger l'utilisateur vers un site frauduleux ou exécuter du code arbitraire.

Elles sont fréquentes dans les attaques XSS, CSRF, clickjacking, ou via des publicités malveillantes (malvertising).

Cross-Site Scripting (XSS)

Injection de scripts malveillants dans une page web pour exécuter du code côté utilisateur

Vol/forge de cookies (tampered cookies)

Exploitation des cookies de session (par vol ou forge) pour usurper l'identité de l'utilisateur



CSRF (Cross-Site Request Forgery)

Exploite la session de l'utilisateur pour exécuter des actions non autorisées à son insu

Man-in-the-Browser

Infection d'un navigateur via un malware pour intercepter ou modifier des données

Clickjacking

Tromper l'utilisateur en lui faisant cliquer sur des éléments invisibles ou détournés

Attaques via plugins

Exploitation des vulnérabilités des extensions ou plugins du navigateur

J. Attaques Server-Side



Les attaques côté serveur visent les serveurs et leur infrastructure pour compromettre les données, les services ou les fonctionnalités de l'application web. Elles exploitent des vulnérabilités dans les logiciels, configurations ou mécanismes de sécurité.

Les principales familles d'attaques web server-side, parmi elles :

- Attaques de découverte/d'énumération
- Attaques d'accès/de contournement
- Attaques d'injection/d'inclusion

Attaques de découverte/d'énumération

Dans le contexte des attaques Web côté serveur, l'énumération consiste à sonder et analyser les réponses du serveur pour identifier des ressources, fonctionnalités, répertoires, fichiers, comptes ou points d'entrée exploitables.

Elle repose sur l'observation des comportements du serveur face à des requêtes modifiées ou malformées, souvent via bruteforce d'URL, fuzzing ou analyse des messages d'erreur.

L'attaquant peut ainsi découvrir :

- Des noms de domaines correspondant à des sous-domaines (ce qui élargit la surface d'attaque)
- Des répertoires sensibles (/admin, /backup...)
- Des fichiers de configuration ou de sauvegarde accessibles
- Des comptes utilisateurs valides via des réponses d'authentification distinctes
- Des API non documentées

C'est une étape préparatoire essentielle avant une exploitation (injection, contournement d'authentification, inclusion, etc...).



Énumération de sous-domaines

Recherche de sous-domaines pour identifier des cibles potentielles ou services vulnérables

Énumération de répertoires

Exploration des répertoires accessibles pour identifier des fichiers ou dossiers non sécurisés



Attaques d'accès ou de contournement

IDOR (Insecure Direct Object References)

Permet l'accès non autorisé à des ressources grâce à des références mal sécurisées

Path Traversal

Exploitation des chemins d'accès pour lire ou modifier des fichiers sensibles



Attaques d'injection ou d'inclusion



Les attaques d'injection ou d'inclusion sont des techniques qui consistent à injecter des données malveillantes dans un champ de saisie ou une requête, dans le but de manipuler le comportement d'une application, d'accéder à des ressources non autorisées ou d'exécuter du code arbitraire.

Ces attaques exploitent le manque de contrôle ou de filtrage des données côté serveur (ou parfois côté client), permettant à un attaquant d'influencer le traitement normal d'une requête, souvent dans le contexte d'un langage ou d'un moteur d'interprétation (SQL, système de fichiers, commandes système...)

Injection SQL

Exécution de commandes SQL malveillantes via des entrées utilisateur

Command Injection

Injection de commandes dans un système pour exécuter du code arbitraire

Remote File Inclusion (RFI)

Inclusion de fichiers distants malveillants via des entrées non sécurisées

Local File Inclusion (LFI)

Inclusion de fichiers locaux ou distants dans l'application, permettant d'exécuter du code malveillant

SSRF (Server-Side Request Forgery)

Force le serveur à effectuer des requêtes non autorisées vers des ressources internes ou externes

RCE (Remote Code Execution)

Permet l'exécution de commandes ou de code malveillant à distance sur le serveur

K. Déni de service (DoS – Denial of Service)

DoS

Ce type d'attaque consiste à rendre indisponible ou à dégrader la qualité de service d'un serveur ou d'un réseau.

Le déni de service peut être de deux types :



- Le déni de service physique consiste à intervenir manuellement sur un serveur ou un équipement réseau : débranchement de l'alimentation, destruction de matériels, modification ou altération de la desserte réseau
- Le déni de service logique consistant à envoyer vers une machine (le plus souvent un serveur ou un équipement de réseau) un volume de trafic tel, qu'elle n'est plus en mesure de servir ses utilisateurs normalement ou devient totalement indisponible

Un déni de service peut aussi être une étape dans la prise de contrôle d'une machine : la mise en œuvre d'un déni de service peut faire appel à l'utilisation d'un virus, ver ou cheval de Troie. Le redémarrage du serveur après cette attaque activera alors le programme malveillant reçu avant l'attaque.

DDoS

Une attaque DDoS (Distributed Denial of Service) consiste à saturer un serveur ou un réseau en envoyant simultanément un très grand nombre de requêtes depuis plusieurs sources (généralement un grand nombre de machines préalablement compromises également appelées PC Zombies).

V. Post exploitation

Une fois qu'un attaquant a compromis un système (via une faille, un phishing ou un accès réseau), il entre dans la phase dite de post-exploitation. Cette étape vise à consolider son accès, collecter des informations, se propager dans le système ou réseau, et préparer l'exfiltration ou la persistance.

A. Etapes clés de la post-exploitation

1. Inventaire du système compromis

- Identification de l'OS, des versions logicielles, des patches de sécurité, des utilisateurs locaux, groupes, politiques de sécurité
- Repérage des fichiers et processus sensibles ou intéressants

2. Élévation de privilèges (Privilege Escalation)

- Recherche de failles ou de mauvaises configurations permettant de passer d'un utilisateur standard à un administrateur
- Exploits locaux et accès à des services mal configurés (ex : service en root avec droits excessifs)

3. Persistance

- Création d'un compte utilisateur ou d'une tâche planifiée
- Insertion de backdoors dans des scripts, services ou fichiers système
- Ajout de clés dans la base de registre (Windows) ou modification de fichiers d'init (Linux)

4. Mouvements latéraux (Lateral Movement)

- Exploration du réseau interne à la recherche de nouvelles cibles
- Utilisation de credentials ou de tickets Kerberos (Pass-the-Hash, Pass-the-Ticket)
- Exploitation de partages réseau, services RDP, SMB, SSH, etc.

5. Vol et collecte de données (Looting)

- Recherche de fichiers sensibles : mots de passe, documents internes, bases de données
- Dump des mots de passe en clair ou hashés (SAM Windows, fichiers de conf, etc.)
- Capture de sessions actives ou de cookies

6. Impact et nettoyage des traces

- Extraction des données vers un C2 en utilisant des tunnels chiffrés, de l'encodage ou des protocoles détournés comme HTTP, DNS ou FTP pour éviter la détection
- Suppression et/ou désactivation des logs système, applicatives et de l'historique de commandes
- Utilisation de rootkits ou d'outils anti-forensic
- Dans le cas d'un ransomware : chiffrement des données et demande de rançon

B. Objectifs

L'objectif final d'un attaquant, après la phase de post-exploitation, dépend de ses motivations : financières, stratégiques, idéologiques ou destructrices.

APT – Advanced Persistent Threat

L'une des approches les plus répandues consiste à établir une présence durable et furtive dans le système compromis. C'est le cas des attaques de type APT (Advanced Persistent Threat), où l'assaillant cherche à maintenir un accès à long terme, en collectant régulièrement des informations sensibles, sans éveiller les soupçons.

Sabotage ou demande de rançon

Une autre finalité possible est le sabotage ou le blocage d'activités, souvent réalisé à travers des rançongiciels (ransomwares). Dans ce cas, les données sont chiffrées ou détruites, et une rançon est exigée pour les restituer. Ces attaques peuvent paralyser des services critiques pendant des jours.

Leaks

Enfin, certains attaquants visent la revente des accès ou des données volées sur le marché noir (dark web). Cela peut concerner des identifiants, des fichiers confidentiels, ou des accès à des infrastructures informatiques. Ces éléments sont ensuite exploités par d'autres cybercriminels pour mener de nouvelles attaques, amplifier les dommages ou générer des profits supplémentaires.